S4E KAYIT OL MODÜLÜ-OTOMASYON TEST ÇALIŞMASI

Register | S4E - Test
Kullanılan Araçlar ve Tech Stack: JavaScript, VsCode, Playwright
Testi Gerçekleştiren: Öner Efe Güngör (onerefegungor@gmail.com)

ID	Senaryo Başlığı	Test Adımları	Beklenen Sonuç	Gerçekleşen Sonuç	Statü
TC01 Happy Path	Form Hazırlığı	1. Geçerli ve uygun formatta verileri gir. 2. Sözleşmeyi onayla.	"Kaydol" butonu disabled durumdan çıkmalı enabled olmalı.	Buton aktif (clickable) duruma geldi.	PASS
TC02 Functional Test	Şifre Görünürlüğü	1. Şifre gir. 2. Göz ikonuna tıkla.	Şifre maskesi kalkmalı.	Karakterler açık metin olarak görüldü.	PASS
TC03 Negative	E-posta Formatı	1. Geçersiz e-posta gir. 2. Odak değiştir.	Hata uyarısı görünmeli.	"Geçersiz e-posta" uyarısı alındı.	PASS
TC04 Negative	Zorunlu Alanlar	1. Zorunlu alanları boş bırak. 2. Formu tetikle.	Uyarı mesajları çıkmalı.	Zorunlu alan uyarıları görüldü.	PASS

TC05 Edge Case(Logical)	Şifre Alanlarının Senkronizasyonu	1. Şifreleri aynı gir. 2. İlk kutudan bir karakter sil. 3.Odağı başka yere kaydır(örneğin e-posta adresi gibi)	Uyuşmazlık uyarısı çıkmalı.	Veriler farklı olmasına rağmen uyarı çıkmadı.	FAIL
TC06 Edge Case(State)	Şifre Alanı Hatası Temizleme	1. Farklı şifreler gir. 2. İlk kutuyu diğeriyle aynı olarak değiştir. 3.Odağı başka yere kaydır(örneğin e-posta adresi gibi.)	Hata mesajı silinmeli.	Şifreler eşitlendiği halde hata mesajı gitmedi.	FAIL
TC07 Edge Case(Data)	Şifreye Boşluk Karakteri Girdisi	1. Şifreye sadece boşluk gir. 2.Odak değiştir. 3.Şifreye boşluk + büyük, küçük harf ve sayı kombinasyonu gir.	Şifre geçersiz sayılmalı veya boşluk sanitize edilip girilen ham string dönmeli.	Boşluklar temizlenmeden, girilen boşluklu şifre received string olarak döndü.	FAIL

TC08 Edge Case(Security)	XSS Tabanlı Input Güvenliği	1. E-posta alanına <script> içeren potansiyel zararlı kodu yaz. 2.Odak değiştir.	Girdiler temizlenmeli veya geçersiz e-posta uyarısı vermeli.	Zararlı kodlar sanitize edilmeden received string olarak döndü ve backende bırakıldı.	FAIL
TC09 Functional Test	Varsayılan Olarak Şifre Maskeleme	1. Sayfayı yükle ve şifre alanının varsayılan ayarlarını kontrol et.	Varsayılan gizli olmalı.	Input type “password” olarak döndü.	PASS
TC10 Negative	Servis Şartları ve Gizlilik Sözleşmesi Onay Kutusu	1. Verileri gir. 2. Sözleşme Checkbox boş bırak.	"Kaydol" butonu pasif kalmalı.	Buton disabled durumda kaldı.	PASS

TEST BULGULARI VE GELİŞTİRME ÖNERİLERİ

Bulgular:

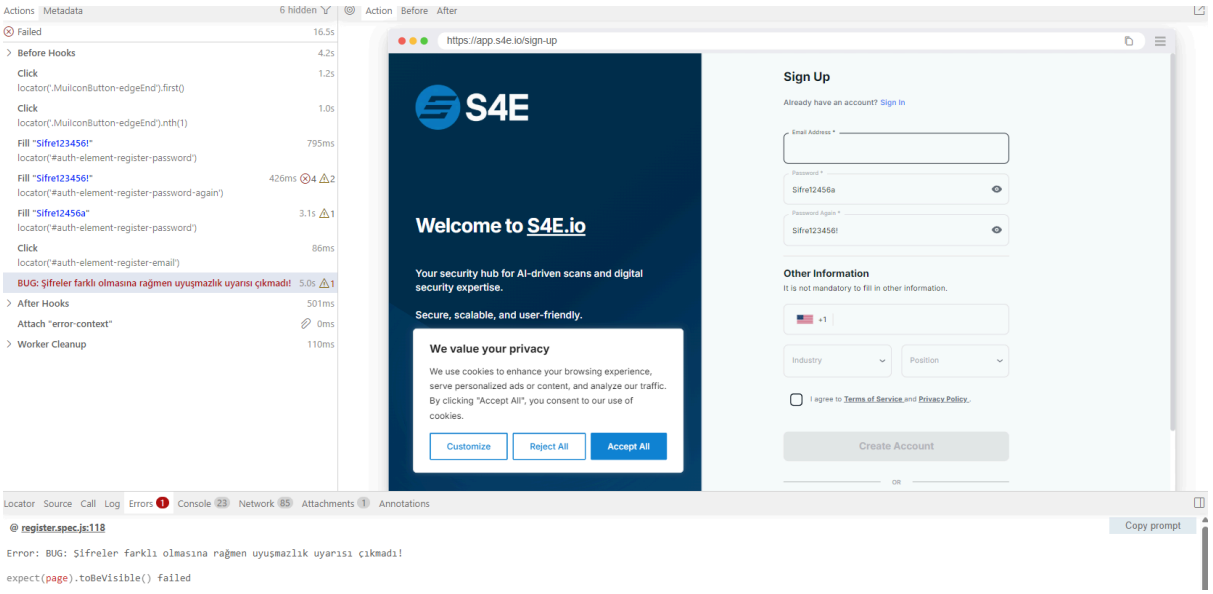
1) *TC05* ve *TC06* kimlikli test senaryolarından yola çıkarak; sistem, şifrelerin senkronizasyonunu sadece “Confirm Password” bölümü ile “Password” bölümünü karşılaştırarak tek yönlü kontrol ediyor. Bu mantık hatası da kullanıcının ikinci kez şifreyi girdiğinde hedeflediği şifreyi girmesi fakat ilkinde gidip ilkini düzelttiğinde sistemin ona yanıltıcı uyarı vermesine veya şifreler uyuşmamasına rağmen kullanıcının bunu ancak “Kayıt Ol” butonuna bastığında fark etmesine yol açıyor. Kullanıcı Deneyimi açısından bu hata kullanıcılar için kafa karıştırıcı olabilir.

2) *TC08* kimlikli senaryoya baktığımızda ise, sistemde “girdiyi temizlemek” konusunda bir eksiklik bulunuyor, e-posta alanında zararlı bir XSS açığı deneyen saldırgan için sistem buna izin veriyor ve ekstra güvenlik kontrolü kısmını backend tarafına bırakıyor. *TC07* kimlikli senaryoda sistem bilinçli olarak, güvenlik sebepleri ile şifre alanında boşluklara izin veren bir yapıyla kurgulanmış olabilir fakat bu durum kullanıcının yanlışlıkla şifresinde boşluklar bırakıp fark etmemesine olanak tanıyabilir.

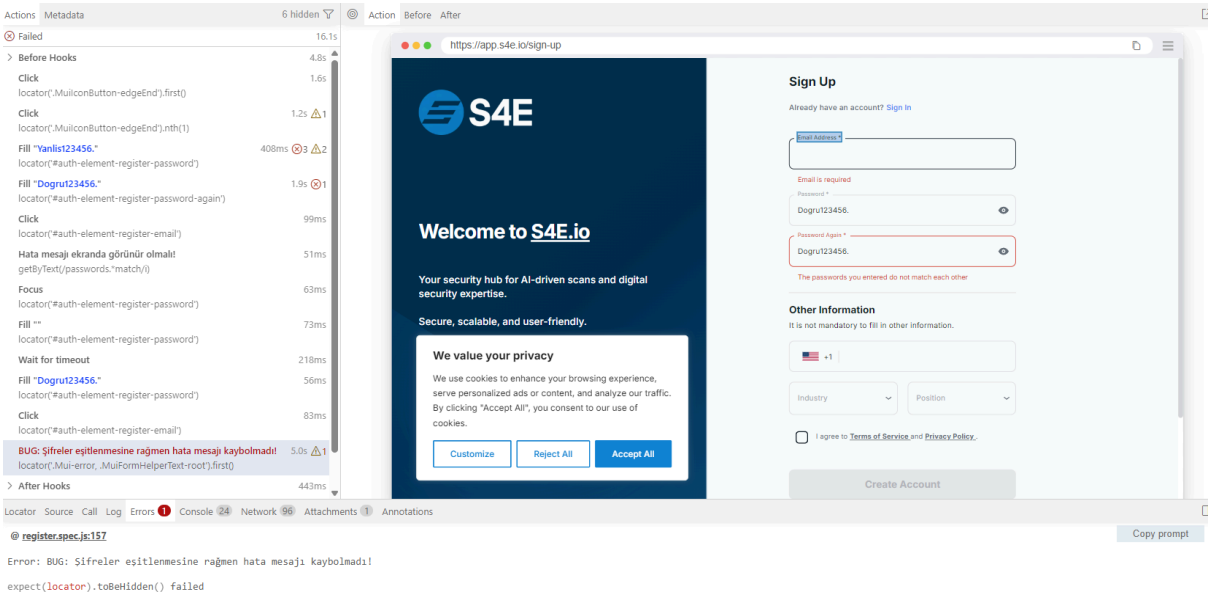
Geliştirme Önerileri:

- ➔ 1 nolu bulgudaki hatanın düzeltilmesi açısından sisteme “çift yönlü” bir senkronizasyon fonksiyonu geliştirilebilir ve bu fonksiyon hem “confirm password” ile “password” kısmının eşitliğini hem de “password” ile “confirm password” kısmının eşitliğini real-time olarak kontrol edip kullanıcıya daha iyi bir deneyim sunabilir.
- ➔ 2 nolu bulguyu manuel olarak sisteme inputu gönderme yöntemi ile test ettiğimde, bu güvenlik zafiyetinin sistemin “backend” tarafında engellendiğini ve kritik bir risk teşkil etmediğini gözlemledim. Fakat backend tarafına bırakılmadan, bu risk bileşeninin; henüz potansiyel tehdit aktörü frontend tarafındayken engellenmesi ve zararlı kodun sisteme dahil edilmemesi önem arz etmektedir. Kullanılan backend servisinin yeni güncellemelerle savunmasız hale gelme olasılığına karşılık “zero-trust” prensibiyle bu veriyi sanitize ederek güvenlik iyileştirilebilir. *TC07* kimlikli bulgu için ise opsiyonel olarak, kullanıcı eğer şifresinde boşluk kullanıp farkında olmama ihtimali düşünülerek kullanıcıyı da yanıltmadan; sarı renkli çok da kritik olmayan bir uyarı mesajı verilerek farkındalık amaçlanabilir, bu bulgunun kullanıcı deneyimine etki seviyesi çok zayıftır ve göz ardı edilebilir.

REFERANSLAR



*1) **TC05** hata görseli.*



*2)**TC06** hata görseli.*

Locator Source Call Log Errors 1 Console 21 Network 80 Attachments 1 Annotations

@ register.spec.js:176

```
Error: BUG: Baştaki boşluklar otomatik temizlenmedi!

expect(received).not.toContain(expected) // indexOf

Expected substring: not " "
Received string:        "  Sifre123"
```

*3) **TC07** hata görseli.*

Locator Source Call Log Errors 1 Console Network 55 Attachments 1 Annotations

@ register.spec.js:186

```
Error: ZAAFİYET İHTİMALİ: <script> gibi zararlı yapılar e-posta input alanında sanitize edilmiyor, backende bırakılıyor.

expect(received).not.toContain(expected) // indexOf

Expected substring: not "<script>"
Received string:        "<script>alert(1)</script>@gmail.com"
```

*4) **TC08** hata görseli.*